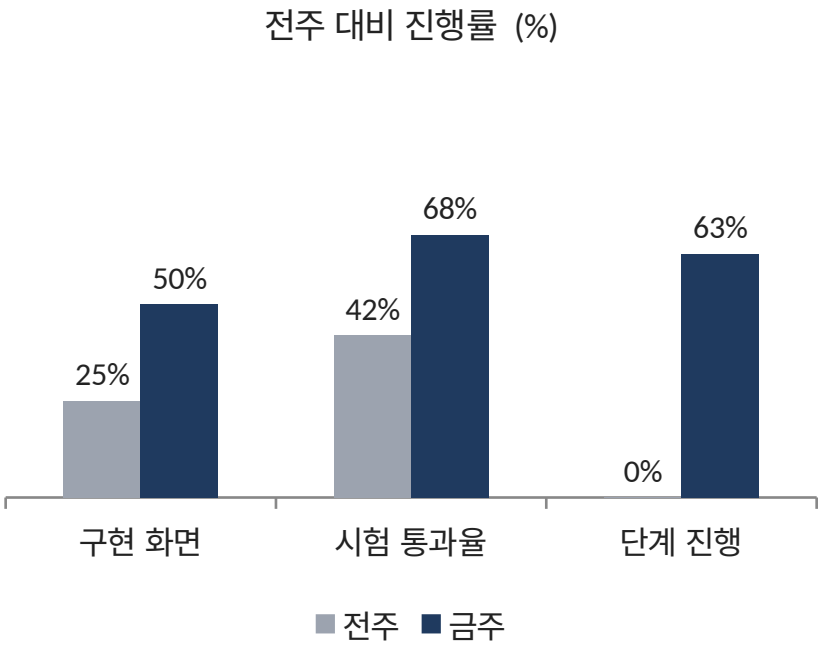
주간 보고

자동화 검증시스템 서비스 개선 및 확장 기능 개발

웹프레임워크 프로젝트 1~5 단계 진행 결과

이상현 | 인하공업전문대학 | 2026.10.25

개발 진도 상황



지표	전주	금주	증감	상태
구현 화면	2/8	4/8	+25%p	계획대로
시험 통과	66/158	138/202	+26%p	진행 중
개발 단계	0/8	5/8	+63%p	계획대로

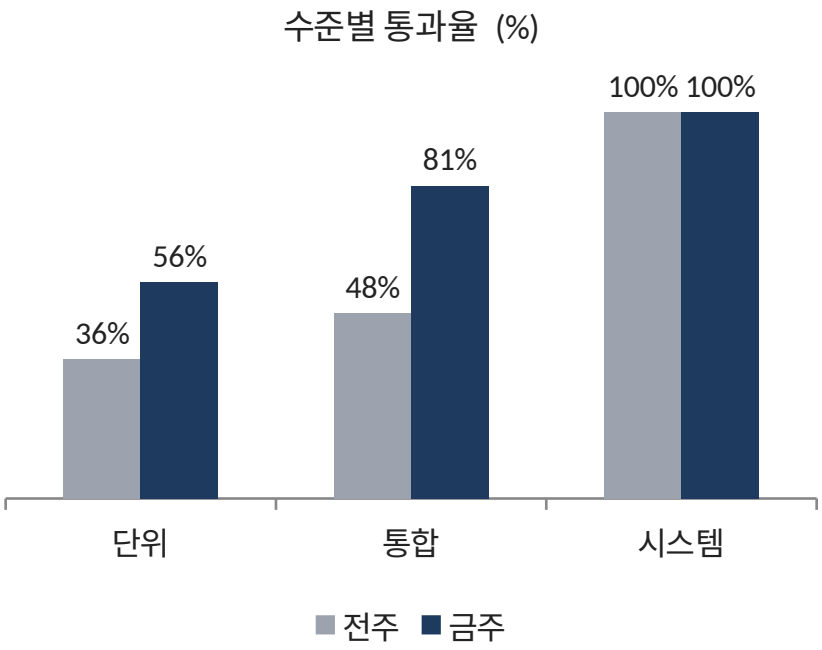
계획 대비
구현 화면 : 이번 주 계획 4/8, 실적 4/8 (편차 0%p)
개발 단계 : 이번 주 계획 1~5 단계 , 실적 5/5 완료
시험 통과 : 목표 비율 미설정 , 잔여 64 건은 구현 전 시험

※ 전주 : 이번 주 작업 착수 직전 시점의 시험 목록을 같은 방식으로 재집계한 값

세부 진행 내역

항목	전주	금주	증감	비고
SC-01 로그인 · 회원가입	완료	완료	-	공격 시험으로 결함 수정 (DF-01~04 등)
SC-02 대시보드	완료	완료	-	공격 시험 통과 , 입력 검증 보강
SC-04 시험 신청	미착수	완료	**신규**	동시 중복 신청 차단 (DF-13)
SC-05 진행 현황 · 심사	미착수	완료	**신규**	동시 승인 · 반려 차단 (DF-14)
SC-03·06·07	미착수	미착수	-	6 단계 예정
AWS 배포	운영 중	운영 중	-	HTTPS, main 병합 후 3 분 내 자동 반영

시험·품질 현황



수준	대상	전주	금주
단위	기능 하나	40/111	64/115
통합	기능 연결	19/40	56/69
시스템	브라우저 조작	7/7	18/18
합계		66/158	**138/202**

분석
증가 44 건 : 공격 시험 28 건 + SC-04·05 시험 16 건
통과 증가 72 건 : 구현 완료로 구현 전 (Red) 해소 + 신규 시험 통과
잔여 구현 전 64 건 : SC-03·06·07, 통합 흐름 시험

결함 현황

영역	건수	높음 / 중간 / 낮음	원인	조치
입력 값 처리	5	0 / 3 / 2	길이 · 형식 · 깊이 검증 부재	**검증 규칙 추가 , 본문 64KB 제한**
로그인 · 보안 설정	6	4 / 2 / 0	길이 한계 , 횟수 제한 부재 , 세션 서버 미관리 , 기본값 의존	**가입 길이 제한 , 5 회 잠금 , 서버 세션 표 , 헤더 추가**
동시 요청	3	3 / 0 / 0	확인과 저장이 분리된 처리	**DB 유니크 인덱스 , 조건부 UPDATE, 일괄 처리**
화면	1	0 / 0 / 1	스타일이 숨김 속성을 덮어씀	**숨김 속성 우선 적용**
합계	**15**	**7 / 5 / 3**	**발견 15 건 , 수정 15 건 , 미수정 0 건**	

※ 높음 7 건 (DF-01~04, 13~15) 은 첨부 1~7 에 수정 전 · 후 화면 수록 . 동시 요청 시험은 5~8 회 반복 실행 .

이슈 현황 1 인증·세션

ID	상황	현상 · 원인	영향	조치 · 상태
DF-01 → 첨부 1	비밀번호 로그인	72 바이트 초과분 미검증 , 멀티바이트 문자 포함 시 뒷부분이 달라도 로그인 성공 (bcrypt 길이 한계)	일부만 맞는 비밀번호로 계정 접근	**72 바이트 초과 가입 거절 , 완료**
DF-02 → 첨부 2	로그인 반복 시도	횟수 제한 없음 , 무제한 입력 (검사 로직 부재)	비밀번호 대입 공격 노출	**5 회 실패 시 429· 잠금 , 완료**
DF-03 → 첨부 3	로그아웃	로그아웃 후에도 기존 세션 쿠키로 접근 (서버가 세션 상태 미보관)	쿠키 탈취 시 계속 접근	**서버 세션 표에서 즉시 폐기 , 완료**
DF-04 → 첨부 4	세션 쿠키 서명	기본 SECRET_KEY 로 임의 사용자 쿠키 생성 가능 (키 하드코딩)	타인 계정 위장	**키 미설정 시 기동 거부 , 완료**

첨부 1 DF-01 비밀번호 72 바이트 초과

수정 전 · 커밋 dbefd7d

```
# 88바이트 비밀번호로 가입
POST /api/auth/signup → 201 Created
{id:2, username:dfone01}

# 끝 글자를 바꿔 로그인
POST /api/auth/login → 200 OK
{id:2, username:dfone01}

→ 73바이트 이후가 잘려 틀린 비밀번호도 통과
```

수정 후 · 커밋 7b53b21

```
# 같은 비밀번호로 가입
POST /api/auth/signup → 400 Bad Request
VALIDATION_ERROR: 비밀번호는 UTF-8 기준
72바이트 이내여야 합니다.

→ 가입 단계에서 거절
```

재현 절차	기대 결과	실제 결과 (수정 전)	영향
72 바이트 초과 비밀번호로 가입 후 , 끝 글자만 바꿔 로그인	로그인 거절 (401)	200 로그인 성공	일부만 맞는 비밀번호로 계정 접근

환경 : 로컬 재현용 서버 , 수정 전 커밋 dbefd7d, 수정 후 7b53b21. 이미지는 실제 요청 · 응답 기록을 옮긴 것 (쿠키 · 키 값 마스킹).

첨부 2 DF-02 로그인 횟수 제한 없음

수정 전 · 커밋 dbefd7d

```
# 같은 계정에 틀린 비밀번호 12회 연속 시도
POST /api/auth/login #01 → 401
POST /api/auth/login #02 → 401
… #03~#11 모두 401 …
POST /api/auth/login #12 → 401

# 이어서 올바른 비밀번호
POST /api/auth/login #13 → 200 OK
→ 횟수 제한이 없어 무제한 추측 가능
```

수정 후 · 커밋 7b53b21

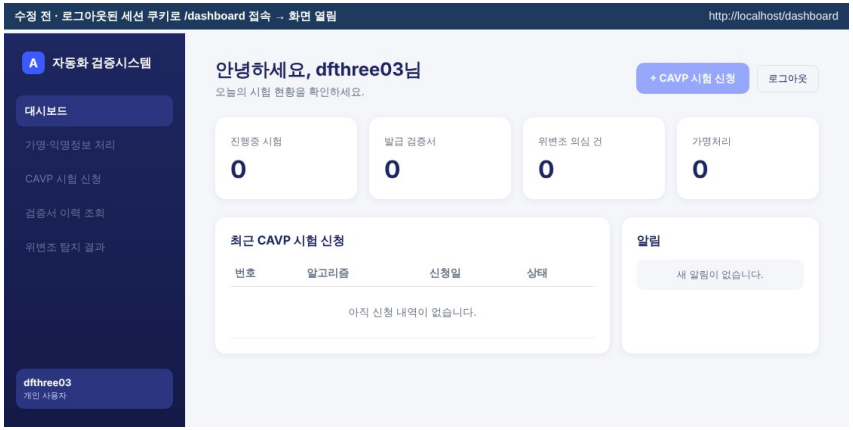
```
# 같은 계정에 틀린 비밀번호 12회 연속 시도
POST /api/auth/login #01~#05 → 401
POST /api/auth/login #06~#12 → 429

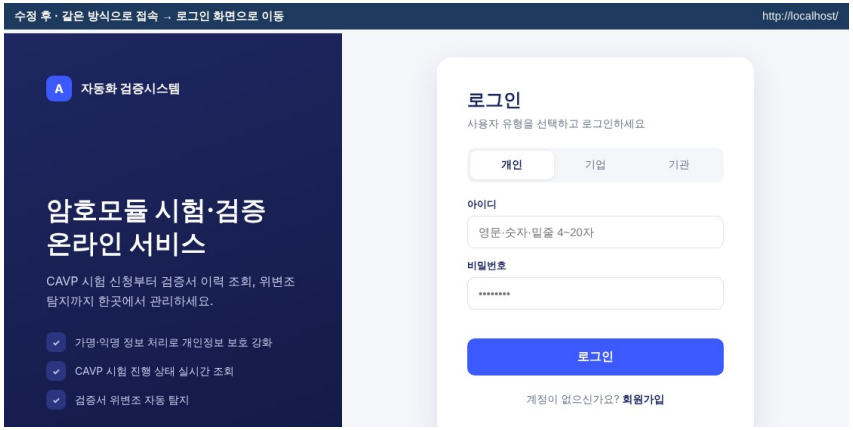
# 이어서 올바른 비밀번호
POST /api/auth/login #13 → 429
TOO_MANY_ATTEMPTS: 로그인 시도가 너무 많습니다.
```

재현 절차	기대 결과	실제 결과 (수정 전)	영향
같은 계정에 틀린 비밀번호 12 회 입력 후 올바른 비밀번호 입력	5 회 실패 후 차단 (429)	**12 회 모두 401, 이어서 200 로그인 성공**	비밀번호 대입 공격 노출

환경 : 로컬 재현용 서버 , 수정 전 커밋 dbefd7d, 수정 후 7b53b21. 이미지는 실제 요청 · 응답 기록을 옮긴 것 (쿠키 · 키 값 마스킹).

첨부 3 DF-03 로그아웃 후 쿠키 재사용





재현 절차	기대 결과	실제 결과 (수정 전)	영향
로그인 후 쿠키 복사 , 로그아웃 , 복사한 쿠키로 /dashboard 접속	로그인 화면으로 이동	**대시보드 화면 표시 (같은 계정)**	쿠키 탈취 시 계속 접근

환경 : 로컬 재현용 서버 , 수정 전 커밋 dbefd7d, 수정 후 7b53b21. 화면은 브라우저 실제 캡처 .

첨부 4 DF-04 기본 서명키로 쿠키 위조

수정 전 · 커밋 dbefd7d

```
# 기본 서명키로 쿠키를 직접 서명
session = sign({"user_id": 5}, key="dev-secret-change-me")

GET /api/auth/me Cookie: **** → 200
{id:5, institution, victim_inst}

→ 로그인 없이 타인 계정으로 인증
```

수정 후 · 커밋 7b53b21

```
# SECRET_KEY 없이 서버 기동
$ python run.py
RuntimeError: SECRET_KEY 환경변수를
설정해야 합니다.
(종료 코드 1)

→ 기동 거부, 위조 쿠키 사용 불가
```

재현 절차	기대 결과	실제 결과 (수정 전)	영향
소스의 기본 키로 사용자 번호 5 의 쿠키 서명 후 /api/auth/me 요청	인증 실패 (401)	**200, 기관 사용자 victim_inst 로 인증**	타인 계정 위장

환경 : 로컬 재현용 서버 , 수정 전 커밋 dbefd7d, 수정 후 7b53b21. 이미지는 실제 요청 · 응답 기록을 옮긴 것 (쿠키 · 키 값 마스킹).

이슈 현황 2 동시 요청

ID	상황	현상 · 원인	영향	조치 · 상태
DF-13 → 첨부 5	시험 신청 (규칙 : 같은 알고리즘은 진행 중 1 건)	16 건 동시 요청 시 중복 신청 6 건 저장 (재현 결과) (중복 확인과 저장 사이에 요청 유입)	중복 데이터 저장	**DB 부분 유니크 인덱스 , 완료**
DF-14 → 첨부 6	심사 (승인 · 반려)	한 신청에 승인 · 반려 동시 처리 시 둘 다 성공 (상태 확인 후 갱신)	이력 불일치	**상태 조건부 UPDATE, 완료**
DF-15 → 첨부 7	로그인 5 회 제한 (DF-02 조치)	24 건 동시 시도 시 5 회 초과 통과 (확인과 횟수 증가 분리), 회귀 결함	대입 공격 재노출	**확인 · 증가 일괄 처리 , 완료**

첨부 5 DF-13 시험 신청 중복 저장

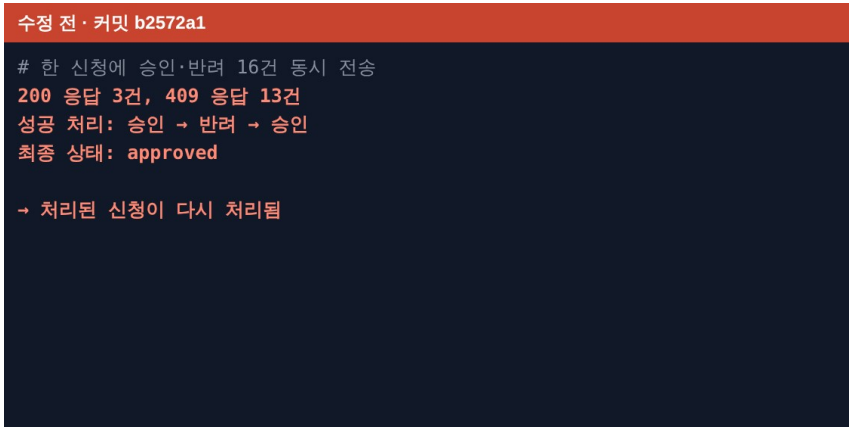


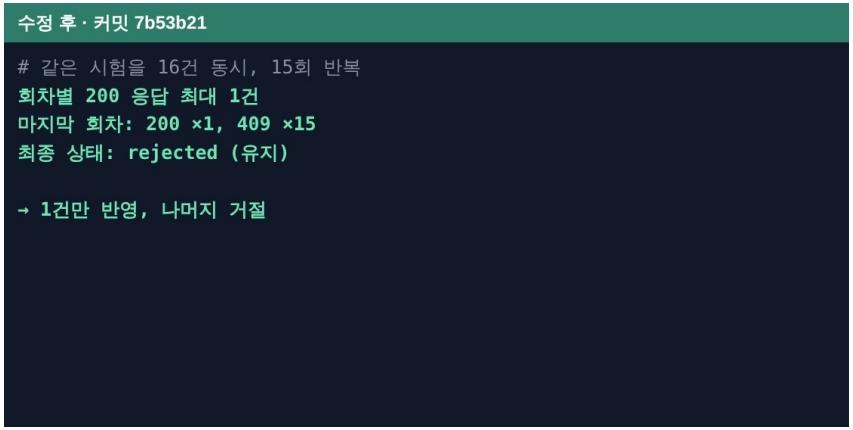


재현 절차	기대 결과	실제 결과 (수정 전)	영향
같은 계정이 같은 알고리즘 (AES) 신청 16 건 동시 전송 후 현황 조회	진행 중 신청 1 건만 저장	201 응답 6 건 , 목록 6 건 저장	중복 데이터 저장

환경 : 로컬 재현용 서버 , 수정 전 커밋 b2572a1, 수정 후 7b53b21. 화면은 브라우저 실제 캡처 .

첨부 6 DF-14 승인·반려 동시 처리





재현 절차	기대 결과	실제 결과 (수정 전)	영향
한 신청에 승인 · 반려 요청 16 건 동시 전송	먼저 처리된 1 건만 성공	200 응답 3 건 (승인 , 반려 , 승인)	심사 이력 불일치

환경 : 로컬 재현용 서버 , 수정 전 커밋 b2572a1, 수정 후 7b53b21. 이미지는 실제 요청 · 응답 기록을 옮긴 것 (쿠키 · 키 값 마스킹).

첨부 7 DF-15 동시 요청 시 횟수 제한 우회

수정 전 · 커밋 b2572a1

```
# 틀린 비밀번호 24건 동시 전송
401 ×24
429 ×0

→ 횟수 제한 전부 통과
```

수정 후 · 커밋 7b53b21

```
# 틀린 비밀번호 24건 동시 전송
401 ×5
429 ×19

→ 5건만 검증, 나머지 차단
```

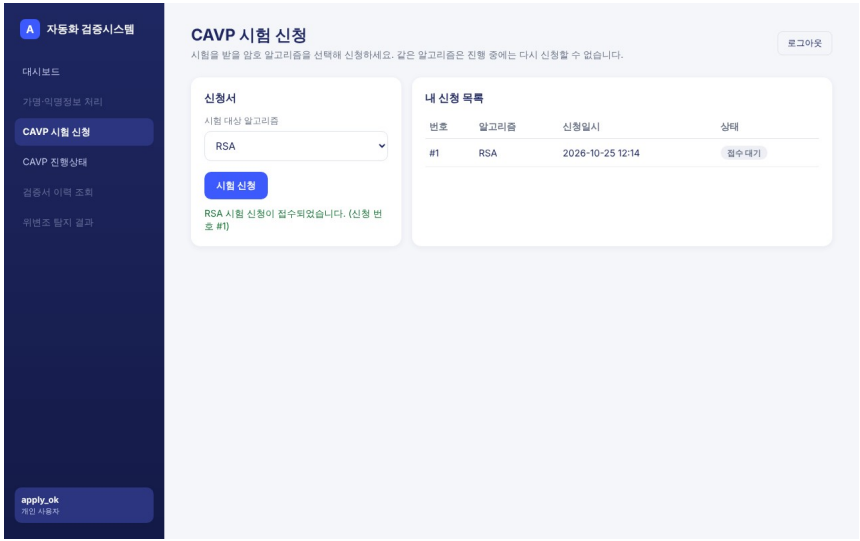
재현 절차	기대 결과	실제 결과 (수정 전)	영향
같은 계정에 틀린 비밀번호 24 건 동시 전송	5 건만 검증 , 나머지 429	401 24 건 , 429 0 건	대입 공격 재노출

환경 : 로컬 재현용 서버 , 수정 전 커밋 b2572a1, 수정 후 7b53b21. 이미지는 실제 요청 · 응답 기록을 옮긴 것 (쿠키 · 키 값 마스킹).

리스크 현황

항목	원인	영향	대응	담당 · 기한
로그인 제한 메모리 기반	횟수를 서버 메모리에 저장	재시작 시 초기화 , 타인 계정 고의 잠금 가능	운영 시 DB·Redis 로 이전	이상현 , 운영 단계 (범위 외)
HTTP(IP) 로그인 불가	Secure 쿠키 기본 적용	HTTP 주소에서 로그인 안 됨 (의도한 동작)	HTTPS(CloudFront) 주소 사용	해당 없음
CSP 부분 적용	화면에 인라인 스크립트 존재	frame-ancestors 만 적용	스크립트 분리 후 확대	이상현 , 미정
클라우드 비용 · 구현 전 64 건	실행 중 요금 발생 , 화면 3 개 미구현	예산 초과 시 서버 자동 정지	발표 후 스택 삭제 , 포트 정리	이상현 , 발표 직후

구현 화면



SC-04 시험 신청 완료



SC-05 심사 (승인 · 반려)

차주 계획

단계	항목	목표	담당 · 기한
6	SC-03 가명 · 익명정보 , SC-06 검증서 이력 , SC-07 위변조 탐지 : 화면별 공격 시험 선작성 후 구현	구현 화면 7/8 (88%)	이상현 , 차주
7	통합 시험 정리 : 전체 흐름 (IT-31), 기초 데이터 (IT-32), 잔여 구현 전 시험	구현 전 64 건 해소	이상현 , 6 단계 후
8	최종 보고서 작성 (결함 대장 기반)	보고서 1 부	이상현 , 7 단계 후

부록 프로젝트 개요 · 용어

배경	국가보안기술연구소의 암호 제품 시험 온라인 서비스 개선 · 확장 과업지시서를 학습용으로 재구성
목표	웹 서비스 구현 + 자동 시험 프레임워크 구축 (15 주 , 1 인)
범위	포함 : 로그인 , 시험 신청 · 조회 , 가명 · 익명 처리 , 검증서 이력 , 위변조 표시 (더미 데이터) / 제외 : 실제 암호 시험 로직 , 실제 개인정보
방식	TDD(시험 먼저 작성), 한 화면씩 구현 후 보고 , 시험 전부 통과 시 main 자동 병합

용어	
CAVP	암호 알고리즘 구현 적합성 시험 제도
검증서	시험 통과 제품에 발급하는 증명 문서
가명 · 익명	개인을 알아볼 수 없게 바꾼 정보
결함	의도와 다른 동작 , 보안 약점 포함
Red/Green	시험 구현 전 / 통과